

How OAuth2 works

Let us start with an interaction diagram (Figure 2).

Here are the steps:

1. User wants to print a photo using a photo application.
2. User opens the photo application.
3. User authenticates using credentials. The application, in turn, contacts the authentication entity (AD, Kerberos, etc) for the user identification.
4. Authentication is successful.
5. Now, OAuth2 comes into play.
6. Photo application contacts authorisation server for access permission with specifying scope (“please allow me to access user’s photos stored in your server”).
7. Auth server silently asks the user if it can trust the photo application.
8. User gives a nod.
9. Auth server issues an authorisation token.
10. The authorisation token is passed to the application.
11. Application asks for an access token for passing the authorisation token.
12. Auth server verifies the auth token, and gives a JWT format access token with a limited expiry. (This double token business — authorisation and access token—is for safety, as it will be very difficult for both to be compromised.)
13. Application securely stores it in its vault.
14. Application contacts the resource server by passing the JWT token as the http *Authorization: bearer <JWT Access Token>* to the resource server (the photo store).
15. The photo is presented to the application.
16. The application processes it and returns it to the user.

OAuth2 and microservices

The workflow we discussed above is the standard reference sequence of how OAuth2 works. However, in practice, we sometimes see a slight variation of the above. Step 9 to Step 11 (authorisation token and access token) are generally shortened into one step. This

variation is called ‘Implicit OAuth2’.

How does this microservice architecture fit into this whole OAuth2 story? The client microservice contacts the auth microservice to acquire the authorisation token and subsequently the access token, to get served by the resource microservices.

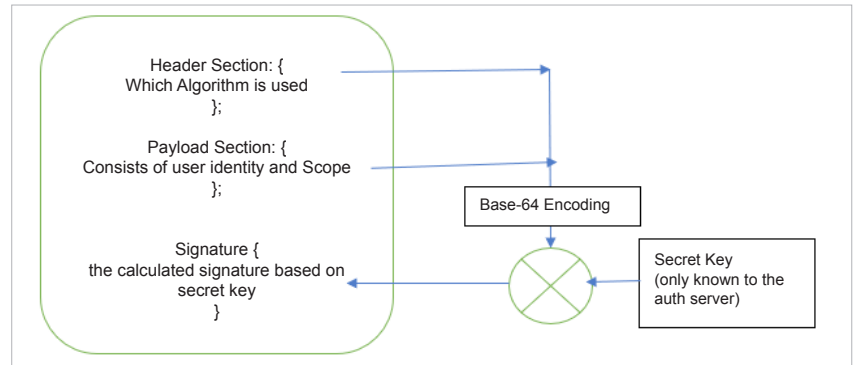


Figure 3: JWT authorisation token

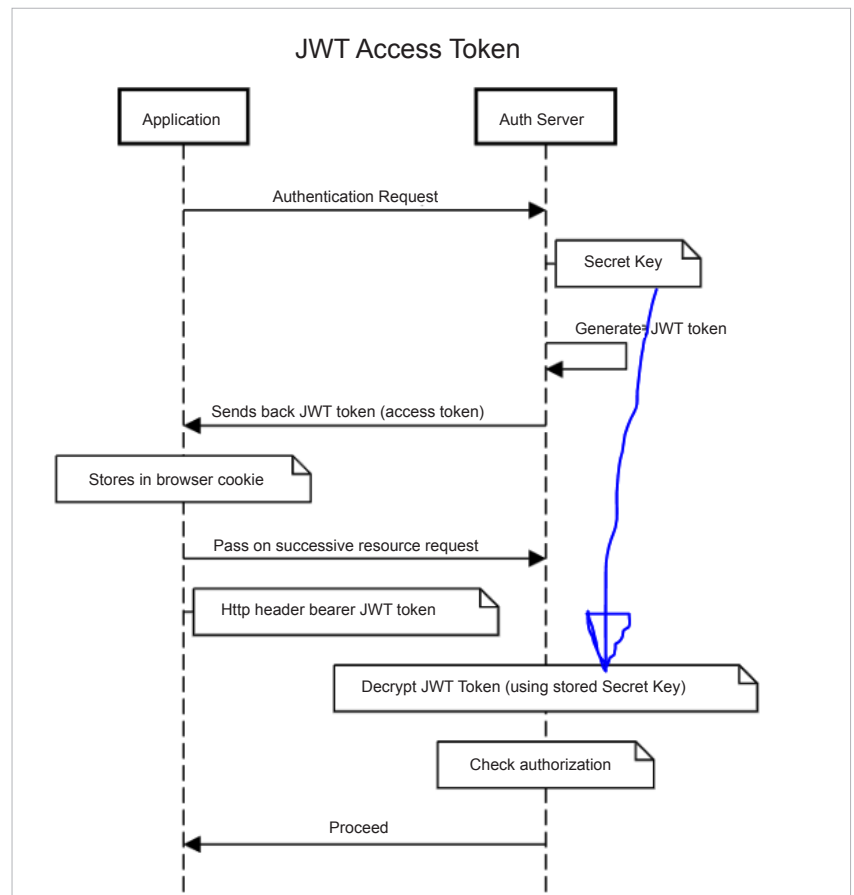


Figure 4: JWT authorisation token sequence diagram